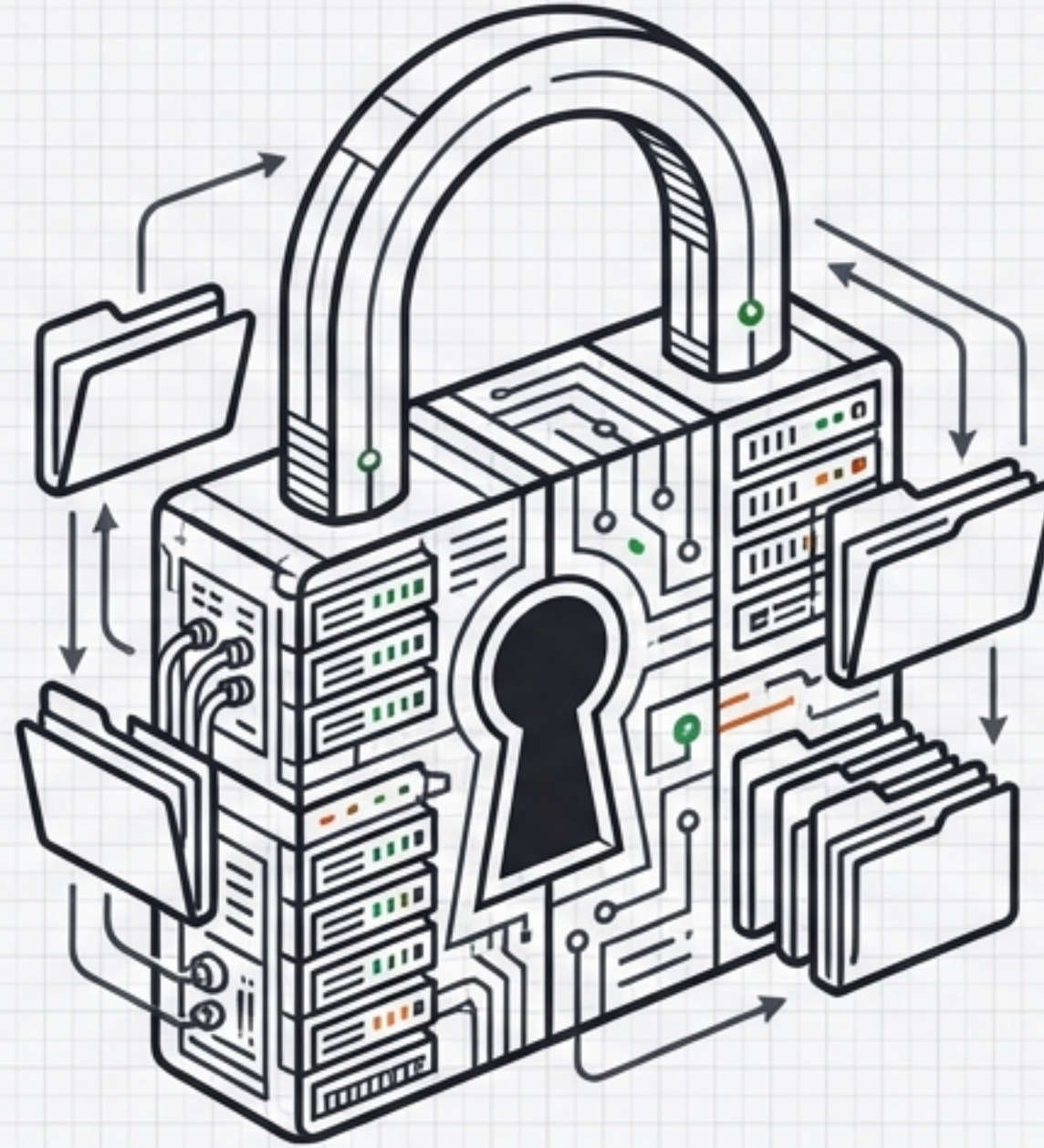


TECHNICAL PRECISION & ARCHITECTURAL CLARITY



SYNTHESIS: SECURITY POSTURE & RISK ASSESSMENT

Architecture, Data Flow, and Compliance for Enterprise Deployment

PREPARED FOR: SECURITY OFFICERS • COMPLIANCE TEAMS • RISK MANAGEMENT

Executive Summary: A Local-First Infrastructure Tool

Narrative

Synthesis operates as local knowledge infrastructure, not a SaaS platform. It possesses zero cloud dependency for core features.

Core Premise

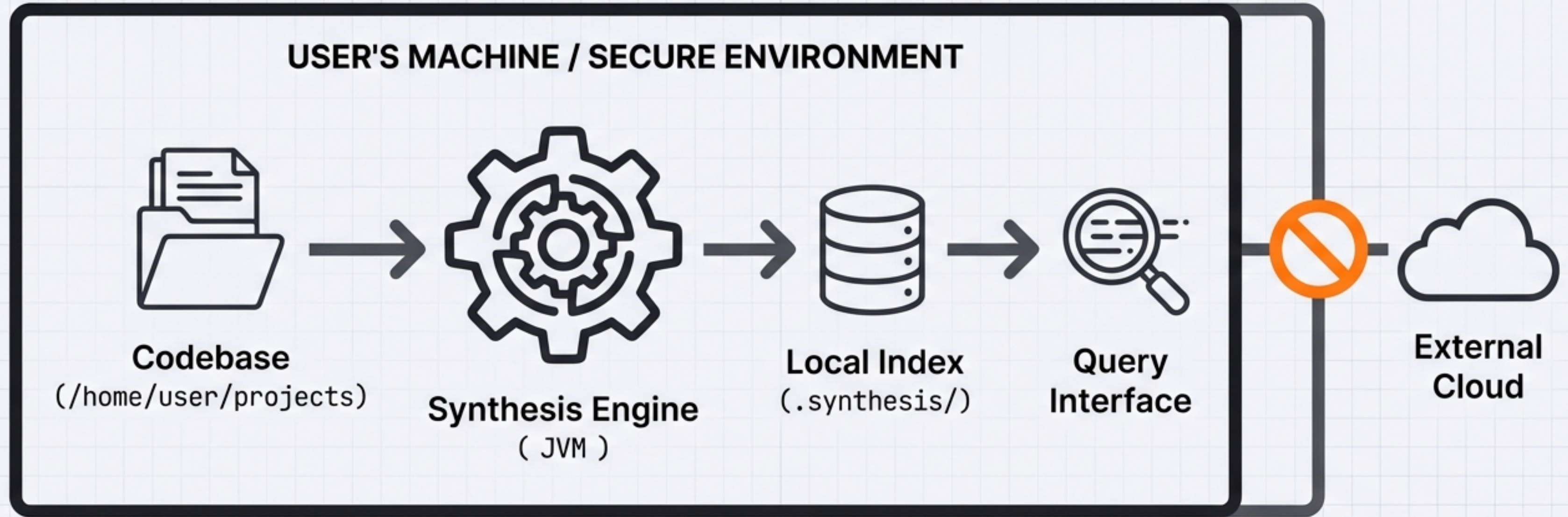
The tool is brought to the data; the data is not sent to the tool.

The Scorecard

	100% Local Processing Scan, search, and graph functions occur entirely on user machine.	
	Zero Network Calls No outbound traffic during normal operation (verified via iptables).	
	No Telemetry by Default Strictly opt-in and anonymous.	
	Open Source Fully auditable code; no black box logic.	
	AI Features Requires explicit opt-in and user action per file.	

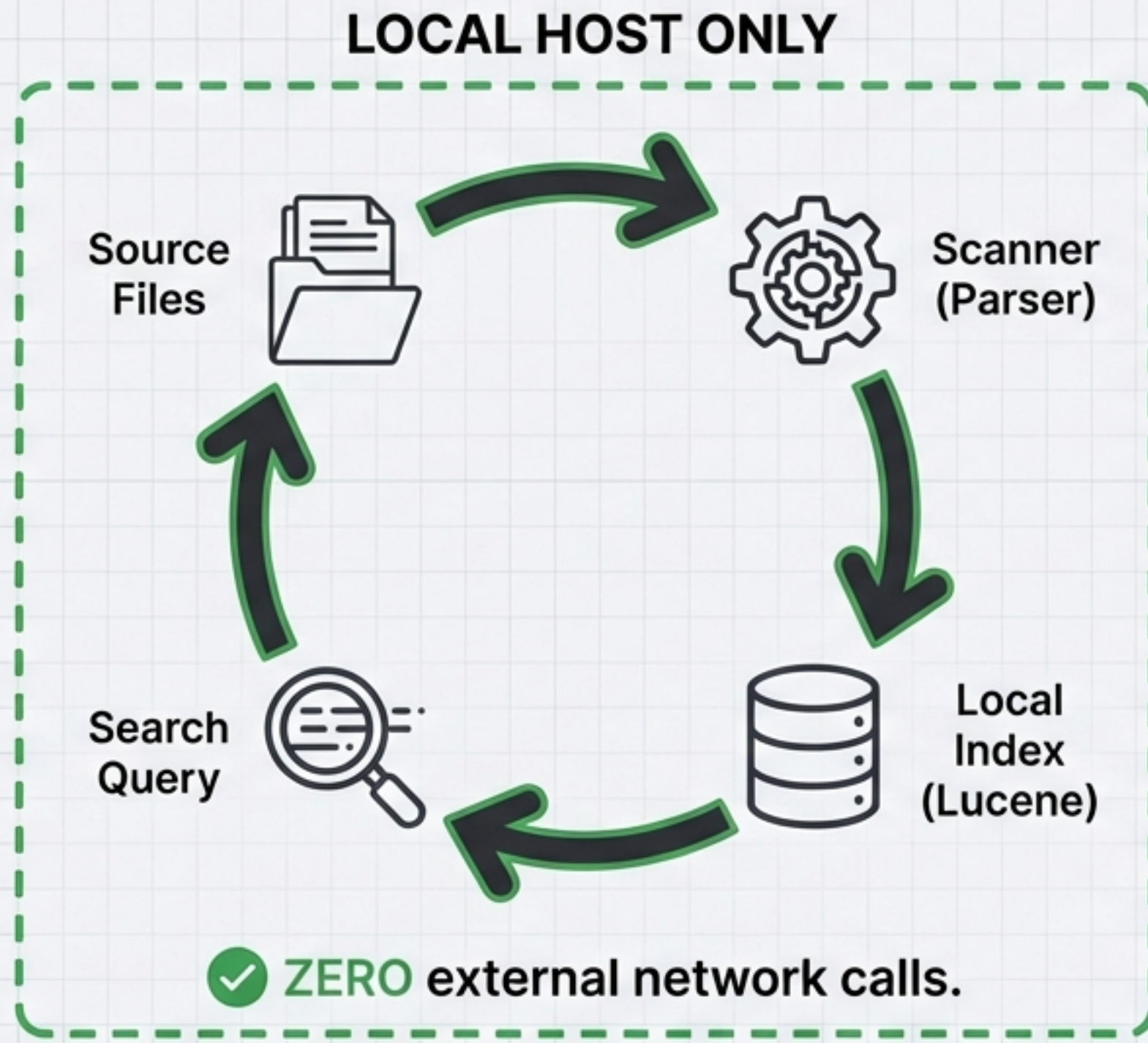
The Sovereign Architecture Philosophy

Unlike SaaS tools that require data exfiltration, Synthesis comes to the data.



The Sovereign Model: Code never leaves the developer's controlled environment.

Data Flow: Core Features (The 'Air Gap')



Technical Evidence

```
Terminal
$ sudo iptables -A OUTPUT -p tcp --dport 443 -j DROP

$ synthesis scan
> Scanning... Done. [Offline Mode]

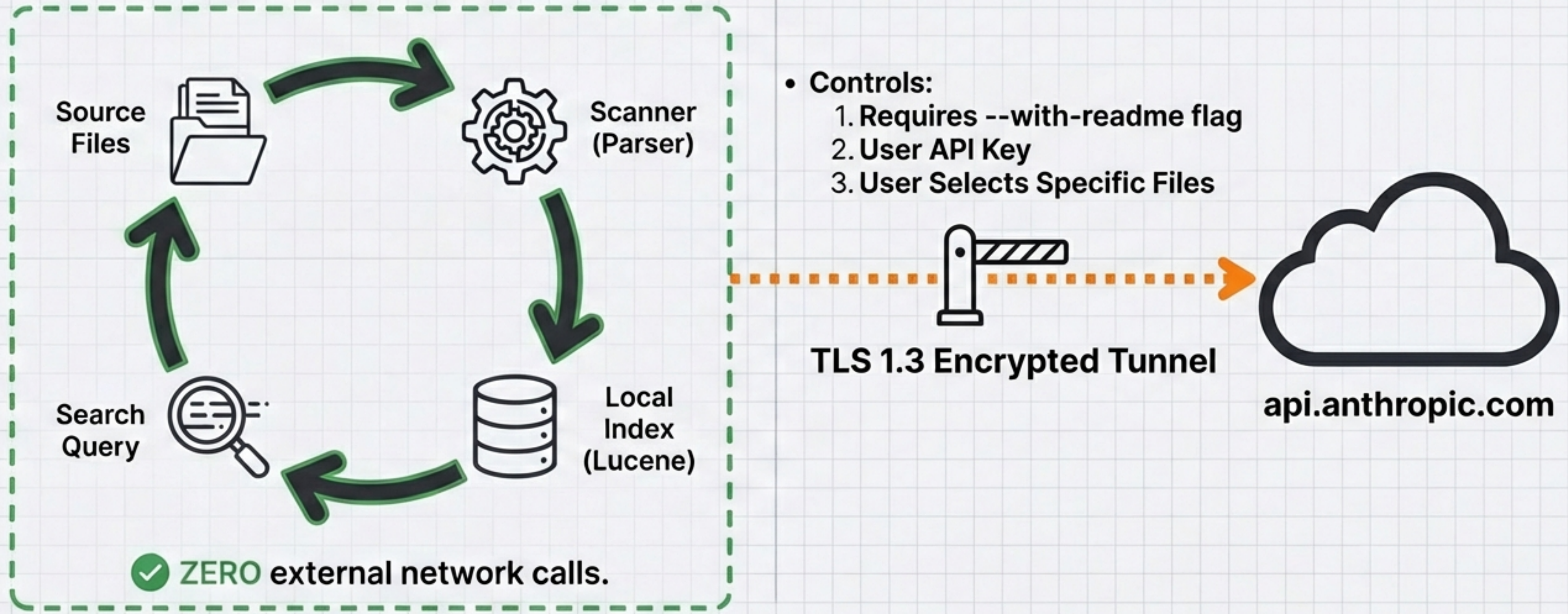
$ synthesis search 'test'
> Found 12 results.

$ # Result: Operations succeed without network. ✓
```


Data Flow: AI Features (The Opt-In Bridge)

Network calls occur ONLY when explicitly enabled by user intent.

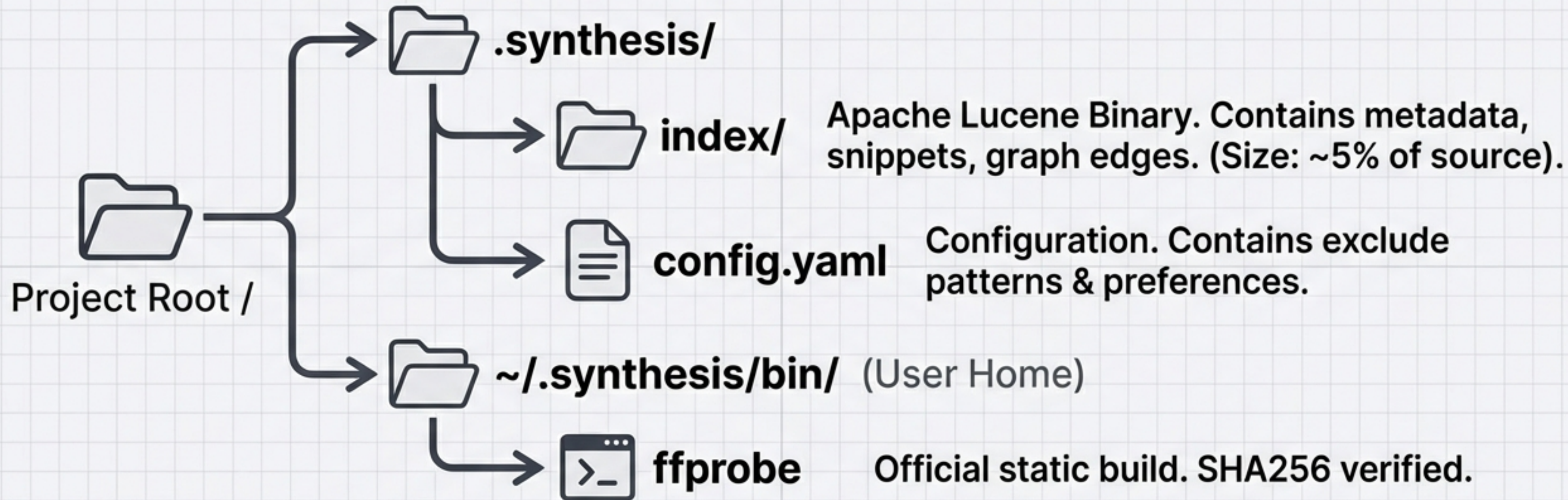
LOCAL HOST ONLY



Risk Bifurcation: The AI features act as a bridge. The entire codebase is NEVER sent; only specific files selected by the user for synthesis are transmitted.

Local Data Storage & Artifacts

Forensic analysis of filesystem footprint.

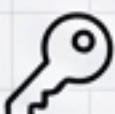
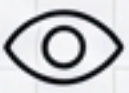
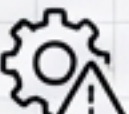
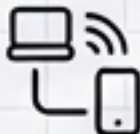


Key Insight:

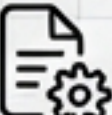
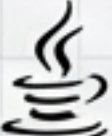
✓ **Safe/Local**

No Full Duplication: Synthesis indexes metadata and snippets. It does not create a full copy of the source code on disk.

Threat Model & Mitigation Strategies

Threat Risk	Likelihood	Impact	Architectural Mitigation
 Source Code Exfiltration 	Low	High	Core features are <u>architecturally offline</u> . No network capability in scanner. ✓ Safe/Local
 API Key / Index Leakage 	Medium	Medium	Standard filesystem permissions (chmod 600). Support for .gitignore .
 Malicious Dependency 	Medium	Medium	<u>Automated CVE scanning</u> . <u>Minimal standard dependencies</u> (Lucene/PDFBox).
 Man-in-the-Middle (AI) 	Low	Medium	<u>Enforced TLS 1.3</u> for all <u>external API calls</u> . → External/Risk

Supply Chain & Dependency Management

Core Components	
	Apache Lucene 9.x (Search Engine)
	Apache PDFBox 3.x (Document Parsing)
	FFmpeg 7.0.2 (Media Metadata)
	JDK 17+ (Runtime Environment)

Security Policy	
	Update Cadence: Security patches applied < 7 days.
	Verification: Checksum validation on all binaries.

Current Status

As of 2026-02-14: No known CVEs in dependency tree. 

What Synthesis Does NOT Do

Negative definitions define the security boundary.



NO Silent Telemetry

Usage data is disabled by default. If enabled, it is fully anonymous.



NO Secret Harvesting

Respects excludePatterns. Does not index .env or key files by default.



NO User Identity Tracking

No login system. No user accounts. No persistent identity.



NO Cloud Uploads of Codebase

Source code is never duplicated to a cloud server. Only specific snippets sent if AI is triggered.

Configuration for High-Security Environments

Recommended settings for Zero Trust, Finance, and Defense deployments.

.synthesis/config.yaml

```
telemetry:  
  enabled: false # Absolute silence  
  
ai:  
  enabled: false # Disable external calls  
  
scan:  
  excludePatterns:  
    - "**/*.key"  
    - "**/*.pem"  
    - "**/.env"  
    - "**/secrets/**"
```

Filesystem Hardening

- Run: `chmod 700 .synthesis/`
- Run: `chmod 600 .synthesis/config.yaml`

Flexible Deployment Scenarios

Standard Developer



Local Install.
User-level permissions.
Standard operation.

Zero Trust / Container



Docker Image:
`eclipse-temurin:17-jre-alpine`

Controls:

- ✓ **Non-root** user,
- ✓ **Read-only** filesystem,
- ✓ **Dropped capabilities.**

Air-Gapped / High Side



- ✗ **Physical Isolation.**
Transfer via USB.
- ✗ **Network interface disabled.**
- ⚠ **AI impossible.**

Regulatory Compliance Mapping

GDPR (Data Protection)



- ✓ **Right to Erasure:** ``rm -rf .synthesis/`` destroys all indexed data instantly.
- ✓ **Sovereignty:** No data transfer outside user control.

SOC 2 / ISO 27001



- ✓ **Access Control:** Relies on OS filesystem permissions.
- **Audit:** Optional telemetry provides usage logs.

HIPAA / PCI-DSS



- ✓ **PHI Handling:** Local indexing carries same risk profile as local IDE.
- ⚠ **Recommendation:** Disable AI features. Use disk encryption.

Incident Response & Vulnerability Management



Reporting Channel:
security@exoreaction.io



Disclosure Policy:
Coordinated disclosure
(90-day embargo).

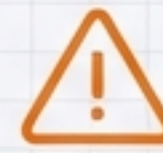


Notification:
Advisories published via
GitHub Releases.

Response SLAs

Safe/Local

External/Risk



Critical:

24h Ack / 7-Day Patch



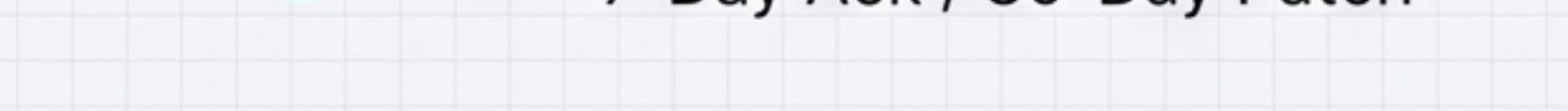
High:

72h Ack / 14-Day Patch



Medium/Low:

7-Day Ack / 30-Day Patch



Frequently Asked Questions

Q: Does Synthesis upload our code to the cloud?

A: No. Core features are **100% local**✅ AI is opt-in only.

Q: Can we use it in an air-gapped environment?

A: **Yes.**✅ The JAR is self-contained. **AI features can be disabled.**

Q: Is the FFmpeg binary safe?

A: **Yes.**✅ It is a checksum-verified official static build from a trusted source.

Q: What if Anthropic is compromised?

A: **Exposure is limited**⚠️ only to the specific text snippets you manually selected to send, not your repository.

Security Checklist for Approval

Requirements for production greenlight.

- ☐ **Architecture Review:** Validate Local-First model.
- ☐ **Policy Decision:** Determine status of AI (On/Off) and Telemetry (On/Off).
- ☐ **Configuration:** Define `excludePatterns` for secrets.
- ☐ **Pilot:** Run in non-production sandbox.
- ☐ **Inventory:** Add Synthesis to asset management.
- ☐ **APPROVE:** Greenlight for deployment.

Date

Signature



Signature 